

El ISO 27001 es un estándar internacional que especifica los requisitos para establecer, implementar, mantener y mejorar continuamente un SGSI (Sistema de Gestión de la Seguridad de la Información) . Es aplicable a cualquier organización, independientemente de su tamaño o sector, su finalidad es proteger la confidencialidad, integridad y disponibilidad de la información mediante un enfoque basado en riesgos. Además se basa en dos principios, los principios técnicos de la seguridad de la información y las estructuras normativas que obligan a la organización.

Principios técnicos (objetivos de seguridad) también llamada tríada CID

Confidencialidad: Es la responsable de garantizar que la información sólo sea accesible por quienes están autorizados.

Integridad: Es el responsable de mantener la exactitud e integridad de la información y los métodos de procesamiento.

Disponibilidad: asegurar que los usuarios autorizados tengan acceso a la información y a los activos cuando lo requieran.

Estructura del sistema para que el sistema sea considerado un SGSI:

(4) Contexto: Identificar las necesidades de las partes interesadas y el alcance del sistema.

(5) Liderazgo: La alta dirección debe demostrar compromiso y asignar roles.

(6) Planificación: identificación y evaluación de riesgos, definición de objetivos de seguridad y tratamiento de riesgos.

(7 )Soporte: recursos, competencias, toma de conciencia, comunicación y documentación.

(8) Operación: implementación de los controles y procesos definidos (incluye tratamiento de riesgos).

(9 )Evaluación del desempeño: seguimiento, auditorías internas y revisión por la dirección.

(10) Mejora continua: acciones correctivas y mejora del SGSI mediante el ciclo Plan-Do-Check-Act.

La ISO 27001 exige que la empresa analice sus propios riesgos y decida qué nivel de protección necesita y se basa en el ciclo PDCA (Plan-Do-Check-Act):

Planificar: Diseñar el sistema y evaluar riesgos.

Hacer: Implementar los controles.

Verificar: Auditar y monitorear el desempeño.

Actuar: Corregir fallas y optimizar procesos.



En un caso hipotético por ejemplo en un hospital solo el médico tratante y las enfermeras asignadas tienen permiso para ver el historial de un paciente, el hospital debe tener un sistema de control de acceso basado en roles (RBAC) esto con el fin de mantener la confidencialidad de los pacientes.

Cómo se vulnera: Un empleado del hospital, por curiosidad, podría acceder al expediente de una persona de interés y filtrar su estado de salud a los medios.

Cuando un médico receta una cantidad de un medicamento, el sistema registra la hora, la firma digital del médico y bloquea el dato para que nadie pueda modificarlo, esto asegura que la enfermera suministre la dosis exacta así manteniendo la Integridad de los datos.

Cómo se vulnera: Un atacante (o un error de software) logra modificar la base de datos y cambia la dosis por una más alta o una insuficiente en la receta de un paciente. Al perderse la exactitud la vida del paciente corre peligro.

El hospital cuenta con servidores redundantes y una planta de energía eléctrica de emergencia. Si el servidor principal falla, el secundario entra en menos de un segundo para que los cirujanos en el quirófano puedan seguir viendo las tomografías en tiempo real manteniendo la disponibilidad de los datos.

Cómo se vulnera: El hospital sufre un ataque de Ransomware que cifra todos los archivos. Los médicos no pueden acceder a los grupos sanguíneos ni a las alergias de los pacientes que están llegando a urgencias, obligando al hospital a desviar ambulancias a otros centros.

Conclusión:

¿Cuál de los 3 pilares consideras más difícil de mantener en la nube?

Considero que de los 3 pilares vistos previamente la que sería la más difícil de mantener en la nube es la de confidencialidad ya que el acceso puede ser vulnerado y se ha visto que los servidores son atacados desde el momento en que los ponen en línea haciendo que si el servidor no tiene las medidas de seguridad adecuadas el acceso a los datos puede ser comprometido

¿Cómo impacta una certificación ISO 27001 en la confianza de un cliente?

Para una empresa que comienza a incursionar en un negocio que utiliza el uso de servidores o incluso solo el uso de páginas web, tener una consultora o un equipo de TI que cuente con certificaciones de seguridad informática brinda automáticamente confianza.

¿Qué sucede si un sistema es confidencial e íntegro, pero no está disponible?

No es óptimo para asegurar que una empresa o individuo acceda a la información y de tratarse de un sistema médico el que cuente con esas características el sistema médico colapsaría ya que no tendrían acceso a los historiales médicos, citas o medicamentos recetados, teniendo asegurada la confidencialidad e integridad pero sin la disponibilidad la triada no se completa y el sistema se vuelve inaccesible dando inseguridad.